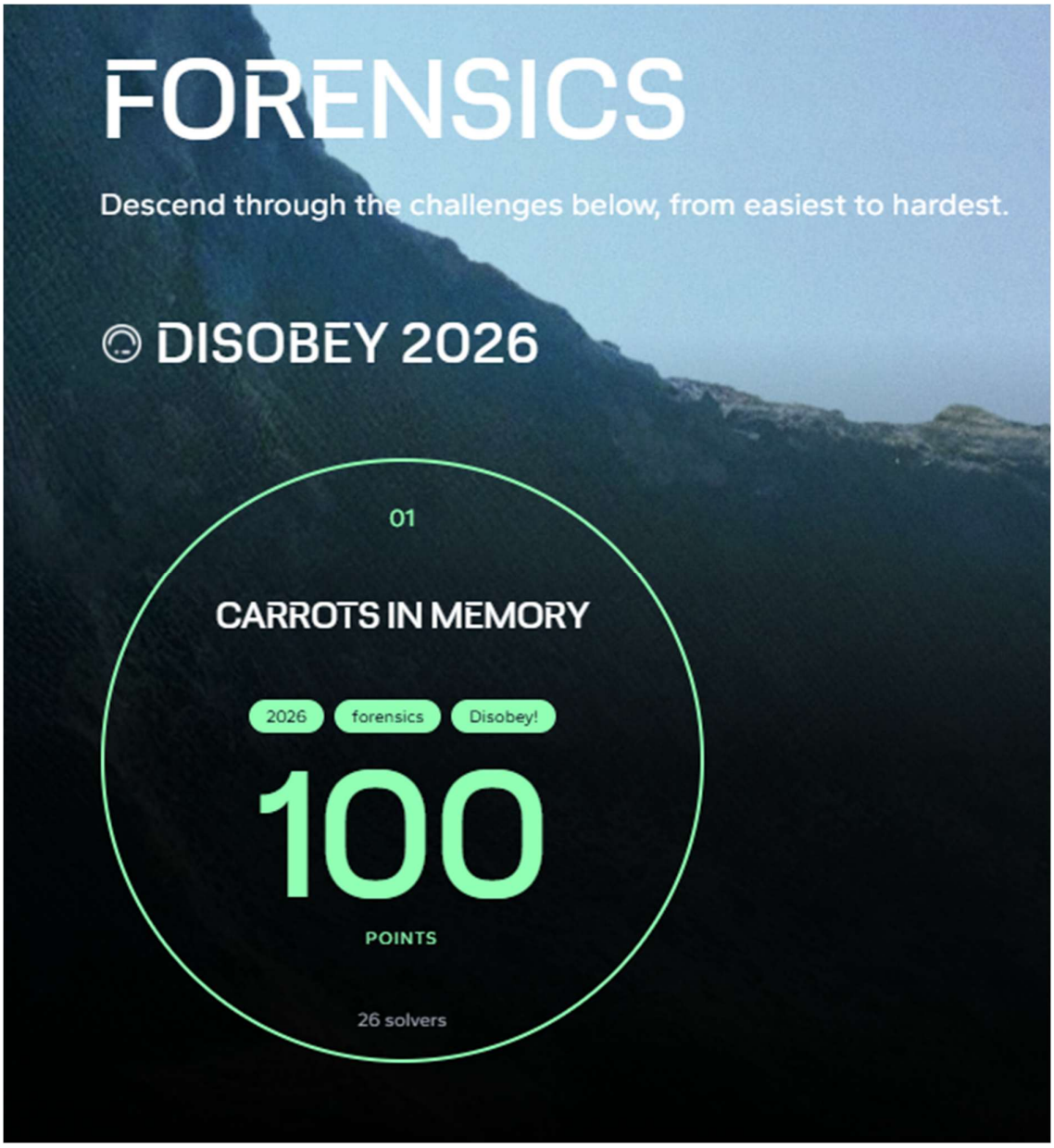
Carrots in memory



Kuvaus: A text file named carrots.txt was used to write a short shopping list and opened with Notepad. The file was later deleted, but a memory dump of the system was captured shortly after. Recover the contents of the file from the provided memory dump.

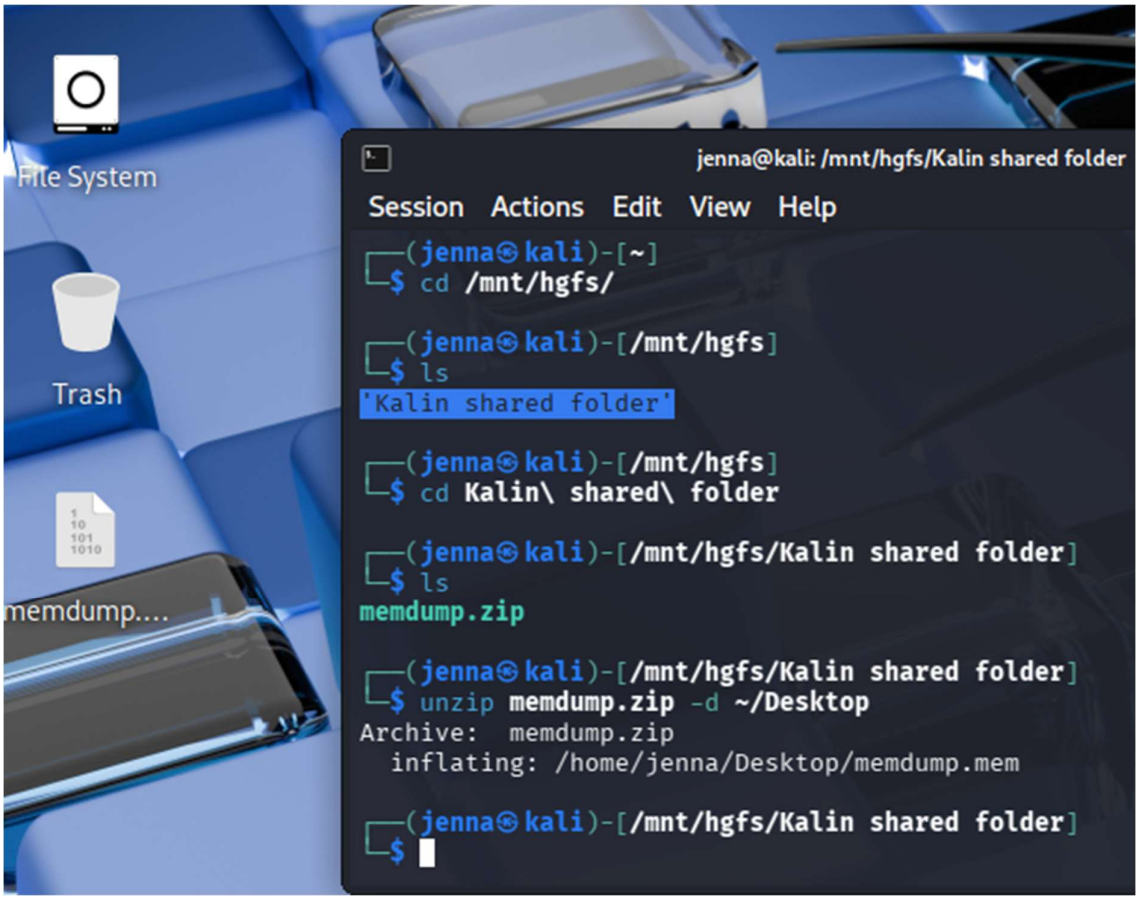
memdump.zip

Hint: If you are doing this from the DNV Cyber booth at Disobey, the memdump.zip can be found predownloaded at /etc/memdump.zip.

Tutkinta

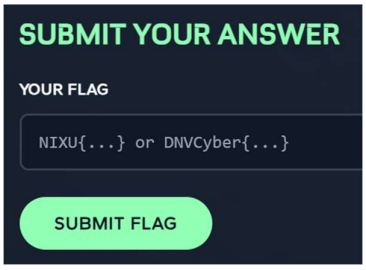
Tehtävänä tuntuu olevan etsiä tiedoston jäänteitä RAM -muistista. Ensimmäisenä työkaluna tulee mieleen Volatility, mutta koitan ensin yksinkertaisempia tapoja etsiä tietoa.

Valmistelin Kali konetta VMWare Workstationilla ottamalla käyttöön Shared Folders ja siirtämällä memdump.mem – kansion Kalikoneelle (kuva 1):



Kuva 1: Memdump.mem hostilta Kalille.

Koitin ensin yksinkertaista grep-hakua, koska tiedossa on lippujen osa: NIXU tai DNVCyber, ja joskus (usein) liput ovat haasteissa puhtaassa tekstimuodossa (kuva 2):



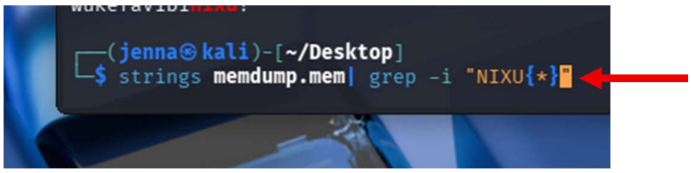
Kuva 2: Lippujen osat tiedossa.

Tämä palautti paljon tavaraa -i vivun vuoksi (kuva 3):



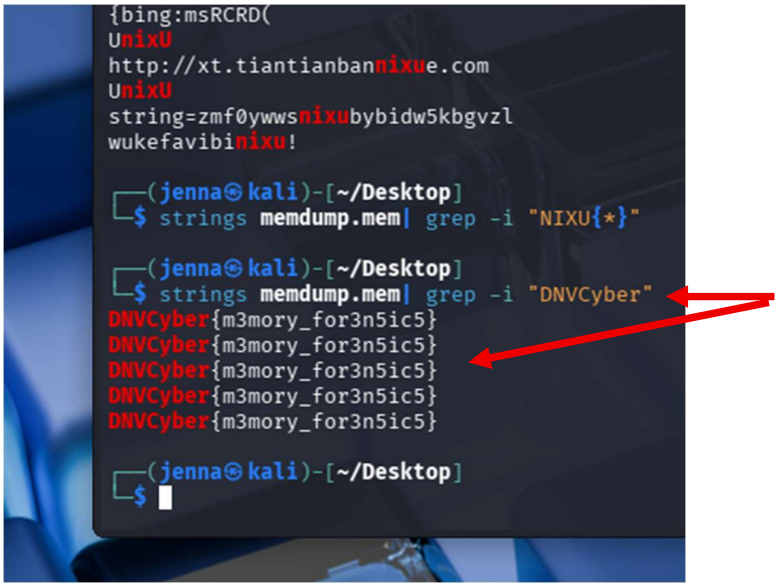
Kuva 3: Ensimmäinen haku.

Koitan tarkentaa hakua (kuva 4):

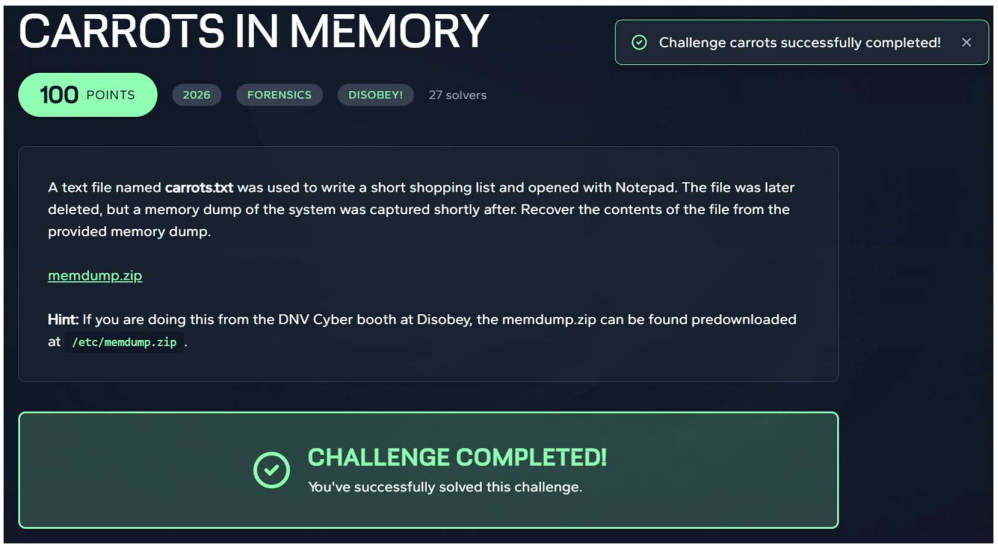


Kuva 4: Tarkennettu haun muoto.

Se ei tulostanut mitään, mutta vaihtaessani toiseen tiedossa olevaan lipun osaan löytyi (kuva 5):



Kuva 5: Ensimmäinen lippu löytyi.

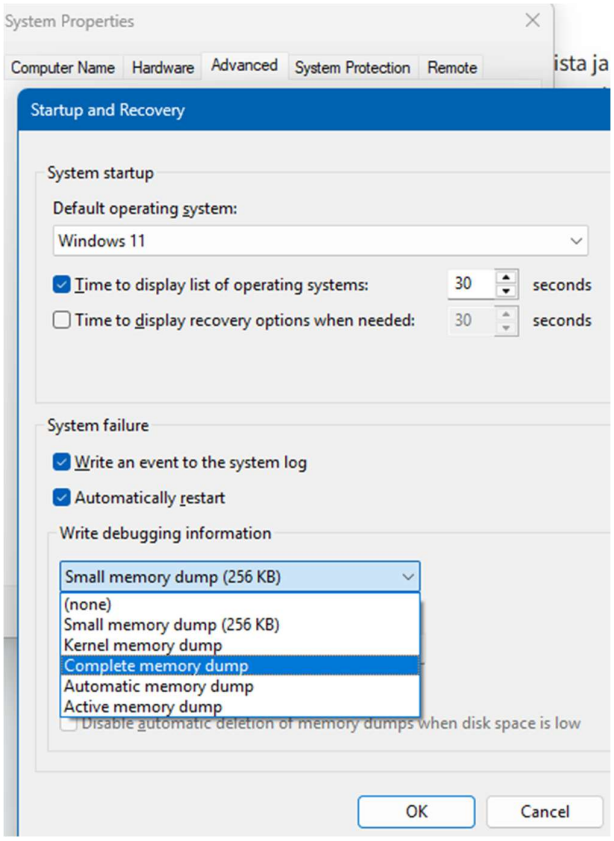


Kuva 6: Carrots in memory-haaste suoritettu.

.mem = tiedostopääte muistivedostiedostolle. Muita tiedostopäätteitä .dmp tai .raw.

Tehtävän memdump.mem on tiedosto, jossa on jonkin tietokoneen tai ohjelman vedos joltain tietyltä hetkeltä. Tehtävän taustatiedoissa kerrotaan tietokoneesta, jolla oli tehty ja jolta oli poistettu tekstitiedosto carrots.txt. Tästä tietokoneesta oli otettu tällainen muistivedos, joka oli tallenenttu nimelle ja tiedostopäätteelle memdump.mem. Englanniksi muistivedosta kutsutaan nimellä memory dump.

Muistivedos voidaan luoda esimerkiksi siihen tarkoitetuilla ohjelmilla. Minun tuntemani ohjelma on FTK Imager. Vedoksia voi luoda myös komentolinjan tai GUI kautta tietokoneen järjestelmän puitteissa (kuva 7):



Kuva 7: Kuvakaappaus host koneeni Startup and Recovery -valikosta.

Muistivedokset ovat tärkeitä esimerkiksi koneen kaatumisen yhteydessä, ja erityisesti kyberturvassa forensiikan osalta. Koska digitaalisessa forensiikassa alkuperäistä laitetta ei tule tutkia, siitä pitää ottaa täydellinen kopio. Tätä vedosta tutkimalla voidaan selvittää alkuperäisen laitteen sisältöä. Myös ”poistettuja” tietoja.

Strings -työkalu haravoi memdump.mem vedoksen bnääridataa, joka ei ole ihmisluettavaa. Strings siis suodattaa tuosta datasta vain luettavissa olevat tekstimerkit.

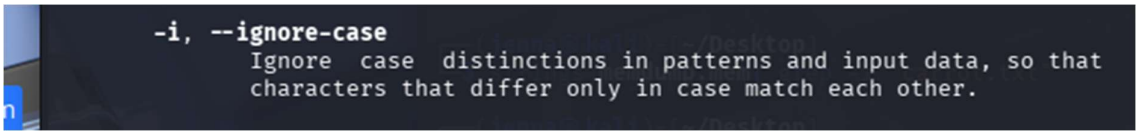
| on putki. Se yksinkertaistettuna yhdistää molemmilla puolillaan olevat komennot vasemmalta oikealle, eli tässä tapauksessa strings | grep. Ilman putkea strings tulostaisi ihan kaiken binääridatan tiedostosta, mutta grepin kanssa se tulostaa vain ne rivit, joista löytyy määrittämäni merkit (esim ”DNVCyber”).

Grep on lyhyesti hakutyökalu. Sillä etsin valitsemiani merkkijonoja.

-i on valitsin. Itse kutsun useimmiten valitsimia joko vivuiksi tai parametreiksi. Minä ymmärrän ne ”filttereinä” tai ”sääntöinä” komentoihini. Linux.fi mukaan ”valitsin, vipu, argumentti, parametri, lippu eli optio on komentorivillä annettava ohjelman toimintaan

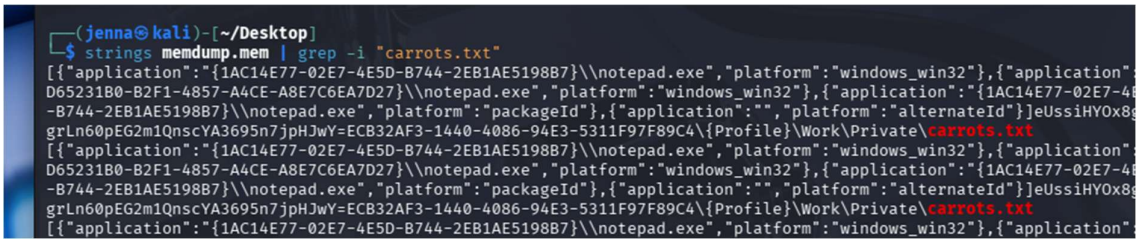
vaikuttava lisäohje, joka yleensä kirjoitetaan ennen mahdollisten käsiteltävien tiedostojen nimiä.” https://www.linux.fi/wiki/Valitsin

Käytin -i -vipua, jotta komento ei välitä (ignore) siitä, ovatko hakuni tulosten kirjaimet isoja vai pieniä (kuva 8).



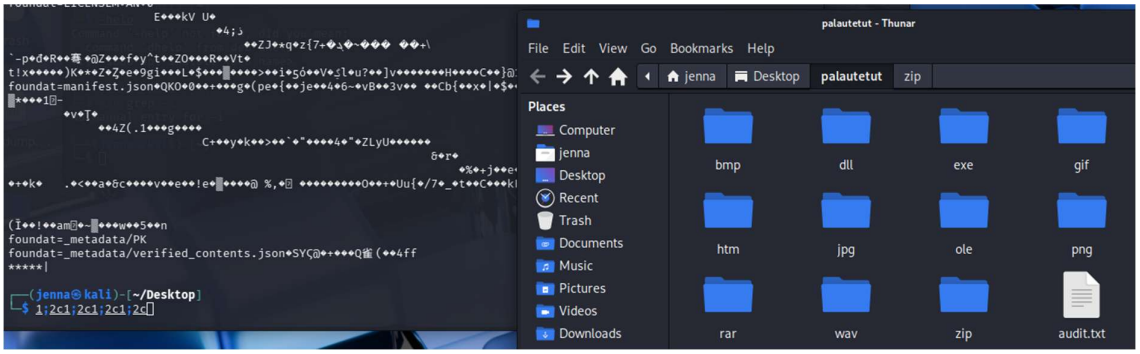
Kuva 8: Man -sivu komennolle grep -i

Jatkoin vielä haasteen kanssa, sillä halusin löytää tuon carrots.txt tiedoston. Rivejä tuli tuolla komennolla taas todella paljon (kuva 9):



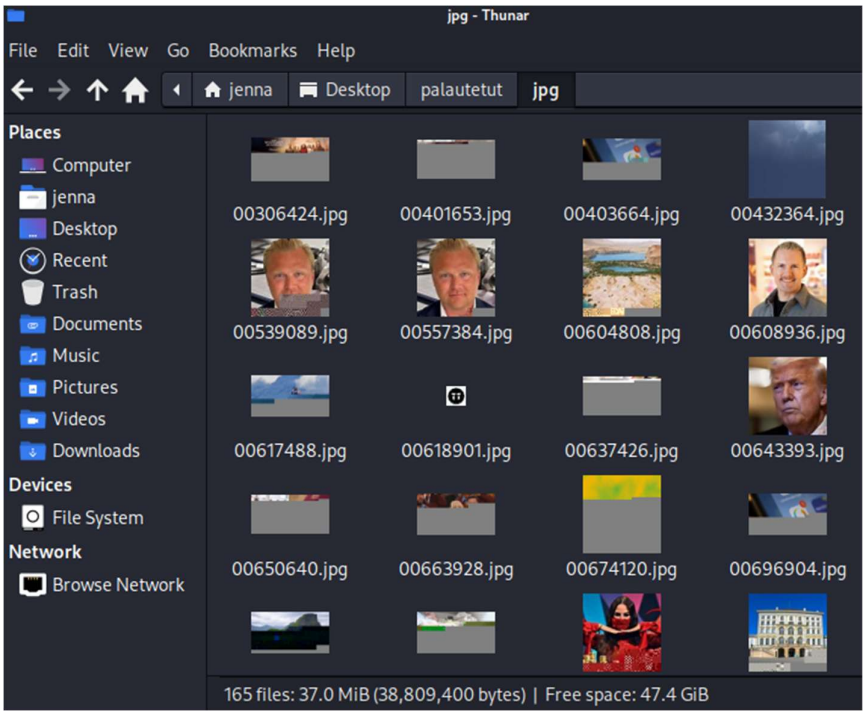
Kuva 9: Strings memdump.mem | grep -i "carrots.txt".

Koitin Kalin Foremost työkalua. Tein työpöydälle uuden kansion palautetut, ja käynnistin foremost, joka käy läpi kaiken muistivedoksesta. Tarkoitus on sitten katsoa, löytyykö sieltä esim txt/ alikansiota, jossa jälkiä tiedostosta voisi olla. Ajon päätytyyä palautetut-kansioon ilmestyi seuraavaa (kuva 10):



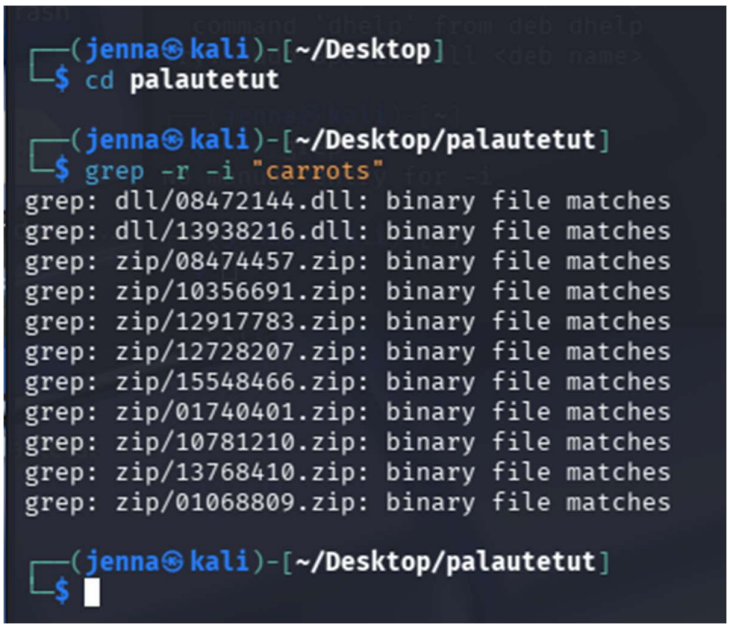
Kuva 10: Oikealla palautetut -kansion sisältö komennon ajon päättymisen jälkeen.

Esimerkiksi jpg -kansiossa oli nähtävissä paljon kuvia (kuva 11):



Kuva 11: Kuvia, joita löytyi muistivedoksesta.

Siirryin terminaalissa palautetut -kansioon ja etsin haulla “carrots” (kuva 12):



Kuva 12: Useita osumia .zip tiedostoissa.

Tämän jälkeen tein uuden kansion, johon purin nuo 9 listatutua zippiä (2 ensimmäistä on windows kirjastotiedostoja): for f in 08474457.zip 10356691.zip 12917783.zip

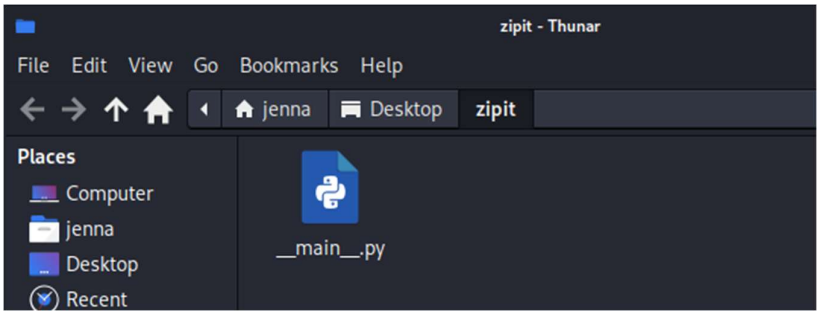
12728207.zip 15548466.zip 01740401.zip 10781210.zip 13768410.zip 01068809.zip; do unzip -o ~/Desktop/palautetut/zip/$f; done

Mitä komento tekee:

Se on lyhyt Linuxin for-looppi. Se ottaa listalta yksi kerrallaan jokaisen tiedoston nimen ja ajaa sille komennon unzip -o "../../palautetut/zip/[tiedostonimi]".

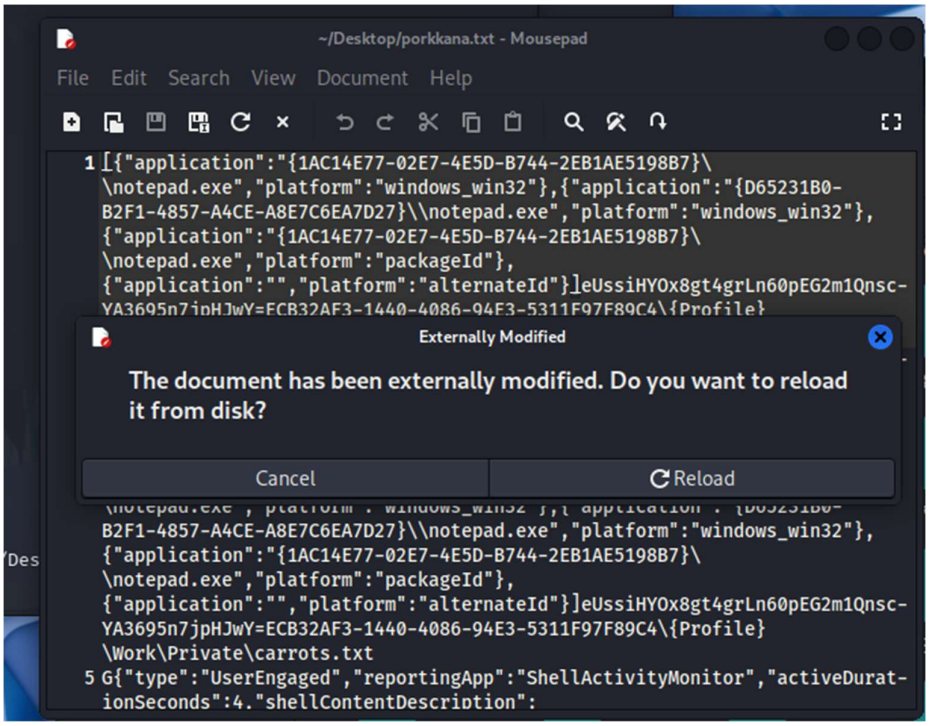
Vipu -o (overwrite) on mukana siksi, että jos useamman zipin sisältä paljastuu samanniminen tiedosto (kuten carrots.txt), komento ei pysähdy kyselemään lupaa vaan korvaa sen lennosta uudemmalla/täydellisemmällä versiolla.

Kansioon zipit ilmestyi .py tiedosto, mutta en perehtynyt siihen sen tarkemmin, koska se oli vain python-standardikoodia pip paketinhallintatyökalun käynnistämiseen (kuva 13):



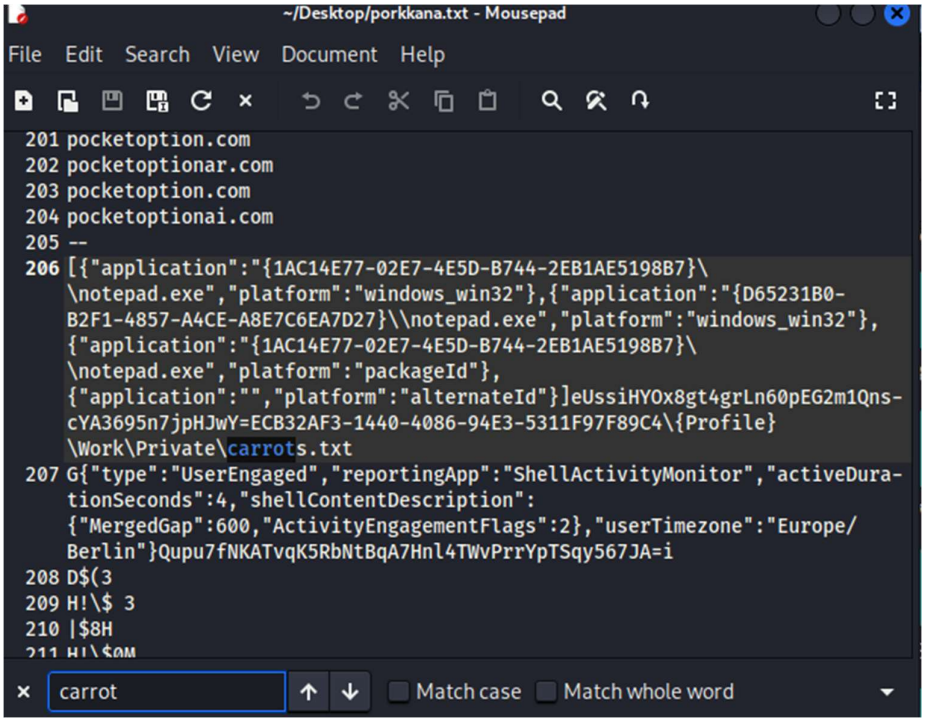
Kuva 13: .py tiedosto.

Menin työpöydälle ja koitin luoda tekstitiedoston porkkana.txt, jos haku löytäisi carrots.txt komennolla strings memdump.mem | grep -i -A 200 "carrots.txt" > ~/Desktop/porkkana.txt. Tiedosto luotiin, ja avatessani sen tuli seuraava ilmoitus (kuva 14):



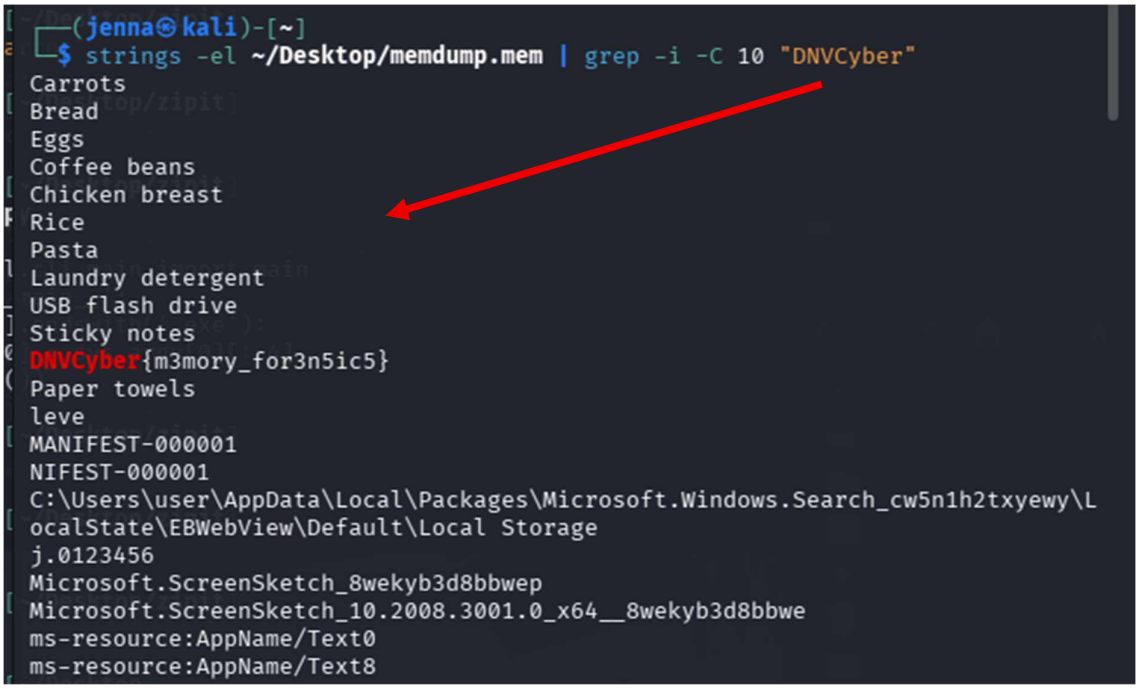
Kuva 14: Komennon strings ~/Desktop/memdump.mem | grep -i -A 200 "carrots.txt" > ~/Desktop/porkkana.txt jälkeen.

Hyväksyin reload.



Kuva 15: Haku tiedoston osalla hakukentässä.

Löysin listan ja sen sisältä myös lipun (kuva 16):



Kuva 16: Haku lipun tiedossa olevalla osalla uudessa terminaalissa. Löytyi lista.